

TLS SERTİFİKALARI · CA/BROWSER FORUM
SC-081V3

Sertifikaların Ömrü 47 Güne İniyor, İnsan Denklemden Çıkıyor

Tarayıcılar ve sertifika otoriteleri, bir web sertifikasının azami ömrünü 398 günden 47 güne indiren bir takvim üzerinde anlaştı. Aynı gün yürürlüğe giren ikinci bir karar, sertifika verirken DNSSEC doğrulamasını da zorunlu kıldı. Böylece bugünkü dersimizin iki konusu, DNSSEC ve TLS, tek bir kararda birbirine kaynadı.

15 Mart 2026, güvenli web için bir dönüm noktası oldu. Tarayıcı üreticileri ile sertifika otoritelerini (certificate authority, CA) aynı masada toplayan CA/Browser Forum'un iki kararı aynı gün yürürlüğe girdi. Birincisi, SC-081v3 sayılı oylama, bir TLS sertifikasının azami ömrünü kademeli olarak kısaltıyor. İkincisi, SC-085v2, sertifika verilirken alan adının DNSSEC zinciri varsa bunun doğrulanmasını zorunlu kılıyor. Bu iki kararın aynı güne denk gelmesi tesadüf değil: ikisi de webdeki güveni yeniden kurgulayan aynı hamlenin parçası. İşte bu yüzden bugünkü dersimizin iki konusu, yani DNSSEC ve TLS, tam da manşette buluşuyor.

47 gün nereden çıktı

SC-081v3, Nisan 2025'te CA/Browser Forum'da 25 kabul, 0 ret ve 5 çekimsiz oyla kabul edildi; öneriyi Apple getirdi, Google, Mozilla ve Microsoft destekledi. Takvim dört aşamalı: sertifika ömrü Mart 2026'da 398 günden 200 güne, Mart 2027'de 100 güne, Mart 2029'da ise 47 güne inecek. Aynı süreçte, alan sahipliğini kanıtlayan doğrulama kanıtının (Domain Control Validation, DCV) yeniden kullanım süresi de 10 güne düşürülüyor; yani her yenilemede alan adı yeniden doğrulanacak. 47 sayısı keyfi değil: 30 günlük bir yenileme döngüsüne, işler ters giderse tampon olsun diye eklenen 17 günlük emniyet payının toplamı.

Neden bu kadar kısa

Asıl gerekçe, iptal sisteminin (revocation) çalışmamasıdır. Ele geçirilmiş bir sertifikayı geçersiz kılmak için kullanılan iptal listeleri (CRL) yüzlerce megabayta ulaşıyor, çevrim içi iptal sorgusu (OCSP) ise sunucu yanıt vermeyince tarayıcı sertifikayı yine de kabul ettiği için işe yaramıyor; Let's Encrypt bu yüzden OCSP'yi 2024 sonunda tamamen bıraktı. Kısa ömürlü bir sertifika ise kendi kendine iptal olur: özel anahtarı çalınsa bile saldırganın elindeki pencere bir yıldan yaklaşık yedi haftaya iner. Kısa ömrün ikinci getirisi, yenilemeyi elle yapmayı imkânsız kılarak otomasyonu zorunlu kılmadır; ACME protokolü (RFC 8555) sertifikayı insan eli değmeden yeniler. Sonuç ilk bakışta ters gelir ama nettir: sertifikaların ömrü kısalдықça, süresi dolduğu için yaşanan kesintiler azalır.

DNS ile kaynak nokta

İkinci karar, SC-085v2, işi bugünkü DNSSEC dersimizin tam ortasına taşır. Bir CA artık sertifika verirken, alan adında DNSSEC etkinse imza zincirini doğrulamak zorunda. 47 günlük bir sertifika yılda tek yenileme yerine yaklaşık sekiz yenileme demek; her yenileme bir doğrulama, her doğrulama bir DNSSEC kontrolü tetikler. Yani DNSSEC kontrol sayısı sekize katlanır. Bunun anlamı şudur: vaka analizlerimizde gördüğümüz .de olayı gibi bir DNSSEC hatası artık yalnız siteyi çözülemez yapmakla kalmaz, sertifika yenilemesini de bloke eder; alan geçerli bir sertifika alamaz ve tarayıcıdaki kilit kırılır.

Sertifika ile DNS güven zinciri artık birbirine kaynamış durumda.

Mimari ders

Sektör, uzun ömürlü ve elle yönetilen güveni, kısa ömürlü ve otomatik güvenle değiştiriyor. Webdeki sertifikaların yaklaşık yüzde 64'ünü veren ve günde 10 milyondan fazla sertifika üreten Let's Encrypt, 6 günlük sertifikaları çoktan sunuma açtı ve varsayılını 45 güne indiriyor. Yenileme hattını otomatikleştirmiş kurumlar için bu geçiş fark bile edilmeyecek; hâlâ takvime not düşüp elle yenileyenler içinse bir hesaplaşma olacak. Buradan çıkan ilke basit: modern altyapıda, bir insanın takvimine bakarak yenilemesi gereken her şey, patlamayı bekleyen gizli bir kesintidir.

VAKA ANALİZİ · ERICSSON / O2 UK · 6 ARALIK 2018

Süresi Dolan Tek Sertifika, 32 Milyon Aboneyi Sustu

6 Aralık 2018'de, İngiltere'nin O2 mobil operatörünün altyapısında bir Ericsson ara sertifikası (intermediate certificate) sessizce süresini doldurdu. Bu tek olay, 32 milyon abonenin on iki saatten uzun süre mobil veri hizmetinden kesilmesine yol açtı. Aynı gün Japonya'da SoftBank de birebir aynı Ericsson yazılımından kaynaklanan aynı kesintiyi yaşadı. Yani hata bir ülkeye özgü değildi; aynı geçmiş tarihe ayarlı sertifika, iki kitada aynı anda patladı.

Kök neden egzotik değildi. Sertifika 15 yıllık bir ömürle kurulmuş, sonra unutulmuştu. Kimse takvime bir not düşmediği için tek bir son kullanma tarihi fark edilmeden geçti ve o an geldiğinde ağ, kendi kimliğini doğrulayamaz hale geldi. Tahmini maliyet 133 milyon doların üzerindeydi; oysa arıza, birkaç baytlık bir tarih alanının geçmişte kalmasından ibaretti.

Bu vaka, manşetteki 47 günlük kural tartışmasının neden başladığını tek başına anlatır. 15 yıllık bir sertifika, unutulmaya davetiyedir; 47 günlük bir sertifika ise kendini yenileyen bir otomasyon hattı kurmaya zorlar. Sertifikaların daha hızlı ölmesi, işte böyle aykırı biçimde kesintileri azaltır, çünkü insanı döngüden çıkarr. Ericsson olayı, döngüde insan kaldığında ne olduğunun kanlı canlı kanıtıdır.

TELGRAF

Kısa Kısa

TSMC TEMMUZDA YÜZDE 44,7 BÜYÜDÜ. TSMC, Temmuz 2026 gelirini yaklaşık 467,58 milyar Yeni Tayvan doları olarak açıkladı; bu, Haziran'a göre yüzde 5,6, geçen yılın Temmuz ayına göre yüzde 44,7 artış demek. Ocak-Temmuz toplamı 2.872,06 milyar Yeni Tayvan dolarına ulaştı ve bir önceki yılın aynı dönemine göre yüzde 37 arttı. İtici güç yapay zekâ çipi talebi.

LET'S ENCRYPT 6 GÜNLÜK SERTİFİKAYI AÇTI. Ücretsiz sertifika otoritesi Let's Encrypt, 15 Ocak 2026'da 6 günlük (160 saat) kısa ömürlü sertifikaları genel kullanıma açtı. İstemenin yolu, ACME istemcisinde 'shortlived' profilini seçmek. Seçim isteğe bağlı; kurum ayrıca varsayılan sertifika ömrünü 90 günden 45 güne indirmeyi planlıyor.

SERTİFİKA VERMEK ARTIK DNSSEC İSTİYOR. CA/Browser Forum'un SC-085v2 kararı 15 Mart 2026'da yürürlüğe girdi: sertifika otoriteleri, alan adında DNSSEC etkinse doğrulama (DCV) ve CAA sorgularında imzaları teyit etmek zorunda. DNSSEC hâlâ isteğe bağlı;

ama açık olup yanlış yapılandırılmışsa sertifika verilmesi tamamen bloke olabilir.

DENIC .DE KESİNTİSİNİN KÖKÜNÜ AÇIKLADI. DENIC, 5 Mayıs'taki .de kesintisinin nihai raporunu 11 Haziran 2026'da yayımladı. Neden, anahtar değişimini yürüten iç geliştirme koduydu: tek bir anahtar çifti yerine her donanım güvenlik modülü için ayrı çift üretildi, üçü de 33834 numaralı aynı etikete sahipti. Sonuçta imzaların yalnızca üçte biri doğrulanabildi.

SERTİFİKA YÖNETİMİNDE BÜYÜK BİRLEŞME. Manşetteki kısa ömür kuralı, değeri sertifika satmaktan yaşam döngüsü yönetimine kaydırıyor. Bu eğilimin işareti, CyberArk'ın 2024'te sertifika yönetimi şirketi Venafi'yi 1,54 milyar dolara satın almasıydı; otomasyon sunamayan otoriteler pazar payını kaybediyor.

BUGÜNÜN DERSİ · AŞAMA 1 · BÖLÜM 2 · MAKALE
5-6

DNSSEC: İmzalı DNS ve Şifreli DNS

DNS aslında güvensiz bir protokoldür: kendisine verilen her yanıtı sorgusuz kabul eder. Bugün önce DNSSEC'in bu yanıtları nasıl imzalayıp sahteciliği yakaladığını, sonra DoT ve DoH'un aynı sorguları nasıl şifrelediğini öğreniyoruz. İkisi ayrı işler yapar: biri imzalar, öteki gizler. Kaynak: Cloudflare Learning Center.

DNS'in eski ve tuhaf bir açığı vardır: kendisine verilen adresi kimlik sormadan kabul eder. Cloudflare'in aktardığı gibi, 2014 Eylül'ünde CMU araştırmacıları, Yahoo, Hotmail ve Gmail üzerinden gitmesi gereken e-postaların sahte posta sunucularına yönlendirildiğini buldu; saldırganlar tam da bu onlarca yıllık açığı kullanıyordu. Çözüm, DNSSEC adlı bir protokoldür. DNSSEC, DNS'in üstüne bir güven katmanı ekleyerek yanıtların kimliğini doğrular: bir çözücü blog.cloudflare.com'u ararken, .com sunucuları cloudflare için dönen kayıtları, cloudflare da blog için dönenleri teyit eder.

İmza eklemek: yeni kayıt türleri

DNSSEC, mevcut DNS kayıtlarına kriptografik imzalar ekleyerek güvenli bir sistem kurar. Bu imzalar, A, AAAA, MX gibi bildik kayıtların yanında saklanır; imzayı kontrol ederek bir kaydın gerçekten yetkili sunucudan geldiğini ve yolda değiştirilmediğini anlarsın. Bunun için birkaç yeni kayıt türü tanımlanır: RRSIG kriptografik imzayı, DNSKEY açık imzalama anahtarını, DS ise bir DNSKEY'in özetini (hash) taşır. NSEC ve NSEC3 ise bir kaydın var olmadığını imzalı biçimde kanıtlamaya yarar, yani 'bu alan yok' demenin bile doğrulanabilir bir yolu olur verir.

İki anahtar: ZSK ve KSK

İmzalama iki anahtar çiftiyle yürür. Bölge imzalama anahtarı (zone-signing key, ZSK) bölgedeki her kayıt kümesini (RRset) imzalar ve imzaları RRSIG kayıtlarında saklar; açık kısmı da DNSKEY kaydında yayımlanır. Ama ya ZSK ele geçerse? İşte burada anahtar imzalama anahtarı (key-signing key, KSK) devreye girer: KSK, açık ZSK'yı imzalar, böylece çözücü önce KSK ile ZSK'yı, sonra ZSK ile kayıtları doğrular. İki ayrı anahtar kullanmanın nedeni pratiktir: KSK'yı değiştirmek zordur çünkü üst bölgeyi de ilgilendirir, ZSK'yı değiştirmekse kolaydır; bu ayırım, sunucunun her yanıta daha az veri taşımasını sağlar.

Güven zinciri ve kök imzalama töreni

DNS hiyerarşik olduğu için güven de yukarıdan aşağı akmalıdır. Bir bölge, KSK'sının özetini alıp üst bölgeye verir; üst bölge bunu bir DS kaydı olarak yayımlar. Çözücü bir çocuk bölgeye yönlendirildiğinde, üst bölge o DS kaydını da verir; çözücü çocuğun KSK'sını özetleyip DS ile karşılaştırır, tutuyorsa çocuğun tüm kayıtlarına güvenebilir. Bu zincir kök bölgeye kadar tırmanır. Ama kökün üstünde ana bölge yoktur; işte orada işin çok insanı bir yüzü belirir. Kök İmzalama Töreni'nde (Root Signing Ceremony), dünyanın dört bir yanından seçilmiş kişiler bir araya gelip kök DNSKEY kümesini herkese açık ve titizce denetlenen bir törenle imzalar.

Özet

DNSSEC, DNS yanıtlarına kriptografik imza ekleyerek sahteciliği yakalar. ZSK kayıtları imzalar, KSK ZSK'yı imzalar, DS kaydı ise güveni üst bölgeye bağlayarak köke kadar uzanan bir zincir kurar. Tıpkı HTTPS gibi güvensiz bir protokolün üstüne güven ekler; ama kritik bir fark vardır: DNSSEC yalnızca imzalar, yani sahteciliği görünür kılar. Trafiği şifrelemez; yanıt hâlâ herkesin okuyabileceği düz metindir.

...

Ve tam da bu boşluk, ikinci makalenin konusudur. DNSSEC imzalar ama gizlemez; peki sorgunun içeriğini yoldaki gözlerden nasıl saklınız? İkinci makale, aynı Cloudflare kaynağının DNS over TLS ve DNS over HTTPS bölümüne dayanıyor.

Neden şifreleme gerekir

DNS sorguları ve yanıtları varsayılan olarak düz metin biçiminde, UDP üzerinden gider; yani ağ yöneticileri, internet servis sağlayıcıları ya da hattı dinleyen herkes bunları okuyabilir. Bir site HTTPS kullansa bile, ona ulaşmak için yapılan DNS sorgusu açıkta kalır. Cloudflare bunu bir kartpostala benzetir: postadaki kartpostalın arkasını eline alan herkes okuyabilir, bu yüzden özel bir şeyi kartpostalla yollamak akıllıca değildir. DNS over TLS ve DNS over HTTPS, tüm bu kartpostalların etrafına birer zarf geçirme çabasıdır.

DoT ve DoH

DNS over TLS (DoT), sorguları HTTPS sitelerinin kullandığı aynı güvenlik protokolüyle, yani TLS ile şifreler ve 853 numaralı portu kullanır. DNS over HTTPS (DoH) ise sorguları HTTP ya da HTTP/2 üzerinden, diğer tüm web trafiğiyle aynı olan 443 portundan gönderir. Temel fark budur: DoT'un ayrı bir portu olduğu için, içerik şifreli olsa da ağdaki biri o trafiğin DoT olduğunu görebilir; DoH ise sorguyu sıradan HTTPS trafiğinin içine gizler, çünkü hepsi aynı porttan akar. Firefox, 2020 Şubat'ında ABD'li kullanıcılar için DoH'u varsayılan yaptı.

Hangisi daha iyi ve DNSSEC'ten farkı

Bu bir denge sorusudur. Ağ güvenliği açısından DoT savunulabilir: yönetici DNS sorgularını görebildiği için kötücül trafiği tanıyıp engelleyebilir. Gizlilik açısındana DoH öne çıkar, çünkü sorgu HTTPS akışının içinde saklandığından yöneticinin görüşü azalır ama kullanıcının mahremiyeti artar. En önemli ayrım şudur: DoT ve DoH sorguyu şifreler, DNSSEC ise şifrelemez, yalnızca imzalar. Yani biri yanıtın kim tarafından yazıldığını garanti eder, öteki yanıtın yolda kimseye görünmemesini sağlar. İkisi rakip değil, tamamlayıcıdır; Cloudflare'in 1.1.1.1 çözücüsü hepsini birden destekler.

Özet

DoT ve DoH, düz metin DNS sorgularını şifreleyerek dinlemeye ve sahteciliğe karşı korur; farkları kullandıkları porttadır: DoT 853, DoH ise 443. DNSSEC'ten ayrıldıkları nokta ise özdür: DNSSEC imzalar ama şifrelemez, DoT ile DoH şifreler ama tek başına imzalamaz. Böylece bir DNS yanıtının iki ayrı güvenlik ihtiyacını, yani doğruluğunu ve gizliliğini, iki ayrı mekanizmayla

karşıladığımızı görmüş olduk.

SÖZLÜK

GÜNÜN SÖZLÜĞÜ

DNSSEC — DNS kayıtlarına kriptografik imza ekleyerek yanıtların sahte olmadığını doğrulayan güvenlik uzantısı. Sahteciliği görünür kılar ama trafiği şifrelemez.

RRSIG kaydı — Bir kayıt kümesinin (RRset) kriptografik imzasını taşıyan DNSSEC kaydı. Çözücü bu imzayı DNSKEY'deki açık anahtarla doğrular.

ZSK / KSK — Bölge imzalama anahtarı bölgedeki kayıtları imzalar; anahtar imzalama anahtarı ise ZSK'yı imzalar. İkisi ayrıdır çünkü KSK'yı değiştirmek zordur, ZSK'yı kolaydır.

DS kaydı — Bir çocuk bölgenin KSK özetini üst bölgede yayımlayan kayıt. Güven zincirini üst bölgeye, oradan da köke bağlar.

DoT / DoH — DNS sorgularını şifreleyen iki standart. DoT ayrı bir portu (853) kullanır ve görünür kalır; DoH sorguyu sıradan HTTPS trafiğinin (443) içine gizler.

TEKNOLOJİ NASIL ÇALIŞIR

Fiber Optik: Işığı Boruda Sektire Sektire Taşımak

İnternette okuduğun bu satırların neredeyse tamamı, saç telinden ince bir cam iplikte ışık olarak yolculuk etti. Fiber optik, bilgiyi bir ışık huzmesine kodlayıp cam ya da plastik bir borudan gönderme sanattır. Teknoloji 1950'lerde doktorların vücut içini görmesi için geliştirildi; 1960'larda mühendisler aynı fikri telefon görüşmelerini ışık hızında taşımak için kullandı. Işık boşlukta saniyede 300.000 kilometre gider, fiberin içindeyse bu hızın yaklaşık üçte ikisine iner; yine de bir e-postayı dünyanın öbür ucuna saniyenin yedide birinde ulaştırır.

Toplam iç yansıma

Işık fiber boyunca, duvarlarına art arda çarparak, buz oluğunda kayan bir kızak gibi ilerler. Cam bir borudaki ışığın kenarlarından sızması beklenir; ama ışık cama yeterince sığır açılıyla, yani 42 dereceden küçük bir açıyla çarparsa, sanki cam bir aynaymış gibi geri yansır. Bu olaya toplam iç yansıma (total internal reflection) denir ve ışığı boru içinde tutan asıl mekanizmadır.

Çekirdek ve kılıf

Işığı içeride tutan ikinci şey, kablonun iki katmanlı yapısıdır. Ortadaki, ışığın içinden geçtiği kısma çekirdek (core) denir. Çekirdeğin çevresini saran cam katmana ise kılıf (cladding) denir ve görevi ışığı çekirdekte tutmaktır. Bunu başarabilmesinin nedeni, kılıfın çekirdekten farklı, daha düşük bir kırılma indisine (refractive index) sahip olmasıdır; işte bu fark, toplam iç yansımanın tam sınırdı gerçekleşmesini sağlar.

Tek mod ve çok mod

Işığın fiberde izlediği yola 'mod' denir. En basit tür tek modlu (single-mode) fiberdir: çekirdeği yalnızca 5-10 mikron (metrenin milyonda biri) çapındadır, ışık ortadan dosdoğru gider ve sinyal 100 kilometreden uzağa taşınabilir; kablo TV, internet ve telefon genelde bu türle çalışır. Çok modlu (multi-mode) fiberin çekirdeği ise yaklaşık on kat kalındır; ışık birçok farklı yol izleyebildiği için modlar birbirinden hafifçe ayrışır (modal dağılım) ve menzil kısılır, bu yüzden çoğunlukla bina içi bilgisayar ağlarını bağlamakta kullanılır.

Bakırın yerini neden aldı

Fiber, uzun mesafede bakır kabloya üç büyük üstünlük taşır: sinyal çok daha az zayıflar (yaklaşık on kat uzağa gider), komşu teller arası parazit (crosstalk) olmaz ve aynı kalınlıkta çok daha fazla veri taşır. Tek modlu bir fiberdeki

laboratuvar rekoru saniyede 178 terabittir. Kıtaları birbirine bağlayan denizaltı fiber kablolarının sayısı 2022 itibarıyla yaklaşık 436, toplam uzunluğu 1,3 milyon kilometredir. Bu düzeni mümkün kılan kuramı 1966'da Charles Kao ortaya koymuş, saf camın uzak mesafe için şart olduğunu göstermiş ve bu buluşuyla 2009 Nobel Fizik Ödülü'nü almıştı.

Mimari not

Bu gazetede günlerdir DNS, DNSSEC, TLS gibi soyut katmanları konuşuyoruz; fiber optik, o soyutlamaların altındaki fiziksel gerçeği hatırlatır. Bir alan adı çözülrken, bir sertifika doğrulanırken ya da bir e-posta MX kaydına göre yölenirken, tüm o bitler eninde sonunda bir cam iplikte sektire sektire giden ışık darbelerine dönüşür. En üstteki güven zinciri ne kadar zarif olursa olsun, en altta onu taşıyan şey, 42 derecelik bir açıya güvenen bir fizik yasasıdır.

KAPANIŞ

GÜNÜN SORUSU

Birincisi: DNSSEC bir DNS yanıtının sahte olmadığını hangi mekanizmayla anlar, ve neden bunu yaparken yanıtı yine de herkesin okuyabileceği düz metin olarak bırakır? İkincisi: DoT ile DoH ikisi de sorguyu şifreler; aralarındaki temel fark hangi portu kullandıklarıdır. Hangisi 853, hangisi 443 portunu kullanır ve bu neden birini ağ yöneticisine görünür, diğerini gizli kılar? Üçüncüsü: manşetteki 47 günlük sertifika kuralı ve SC-085v2 birlikte düşünüldüğünde, DNSSEC'i açık olup yanlış yapılandırılan bir alan neden bir süre sonra geçerli bir sertifika alamaz hale gelir? Üçünü bağlayabiliyorsan bugünün iki dersi oturmuş demektir.

İLERLEME

Aşama 1 / 11 · İnternet ve Ağ Temelleri

Bölüm 2: 6/7 · DNSSEC ve şifreli DNS (DoT/DoH) tamamlandı

Sıradaki · Bölüm 2, Makale 7 — Anycast DNS: tek bir IP adresini dünyanın her yerinden aynı anda sunmak

Pratik ödev · Terminalde dig alan.com DNSKEY ve dig alan.com DS ile bir alanın DNSSEC anahtarlarına bak · dig +dnssec ile bir yanıtın RRSIG imzasını gör · bir alanı 1.1.1.1 üzerinden DoH ile çözmeyi dene

YARIN: Anycast DNS. Namecheap ve .de kesintilerinde gördüğümüz dayanıklılık sorununun cevaplarından biri. Tek bir IP adresi, dünyanın onlarca noktasından aynı anda nasıl sunulur, ve bir veri merkezi çökerse sorgu neden en yakın ayakta olana kayar?

KAYNAKLAR

Bu Sayı Nereden Geldi

cloudflare.com/learning/dns/dnssec/how-dnssec-wor ks — DNSSEC nasıl çalışır

cloudflare.com/learning/dns/dns-over-tls — DNS over TLS ve DNS over HTTPS

captaindns.com/en/blog/tls-certificate-validity-reduc tion-47-days — SC-081v3 ve SC-085v2

letsencrypt.org/2026/01/15/6day-and-ip-general-ava ilability — 6 günlük sertifikalar

pr.tsmc.com/english/news/3329 — TSMC Temmuz 2026 gelir raporu

blog.denic.de/en/final-report-dns-outage-of-5-may-2 026 — .de kesintisi nihai raporu

explainthatstuff.com/fiberoptics.html — fiber optik nasıl çalışır